🛡️ HACKER WOMEN COUNCIL — ETHICAL HACKING

Actividad y 04 - WEB SECURITY CHALLENGE

👤 Karen Itzel Jaime Castillo

📄 **Documentación y Guía Completa de Trabajo**

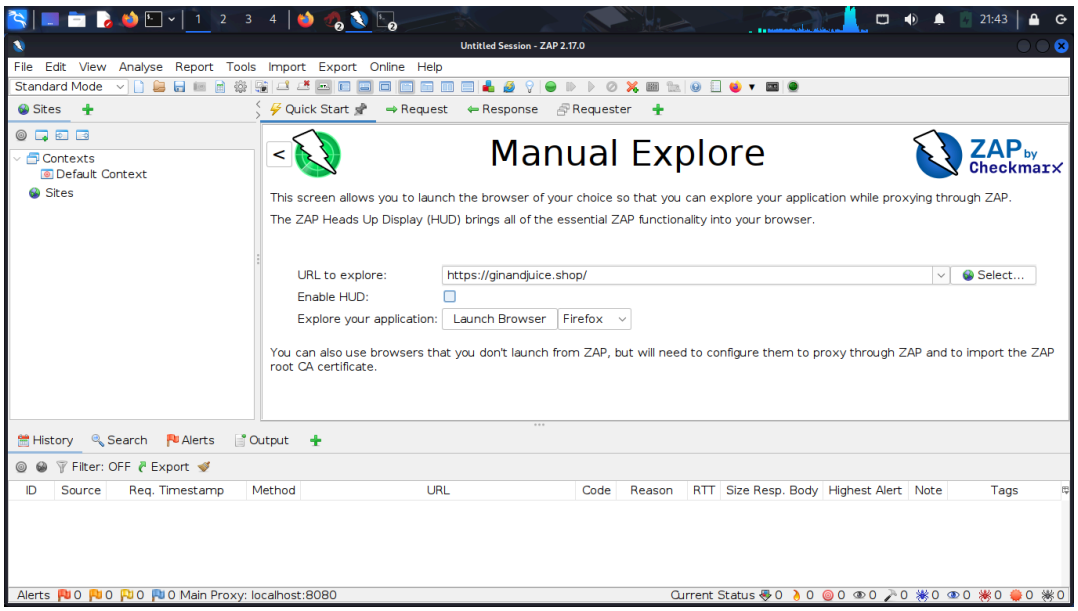
🎯 **Objetivo Autorizado:** https://ginandjuice.shop/

📅 **Fecha:** 27/10/2026

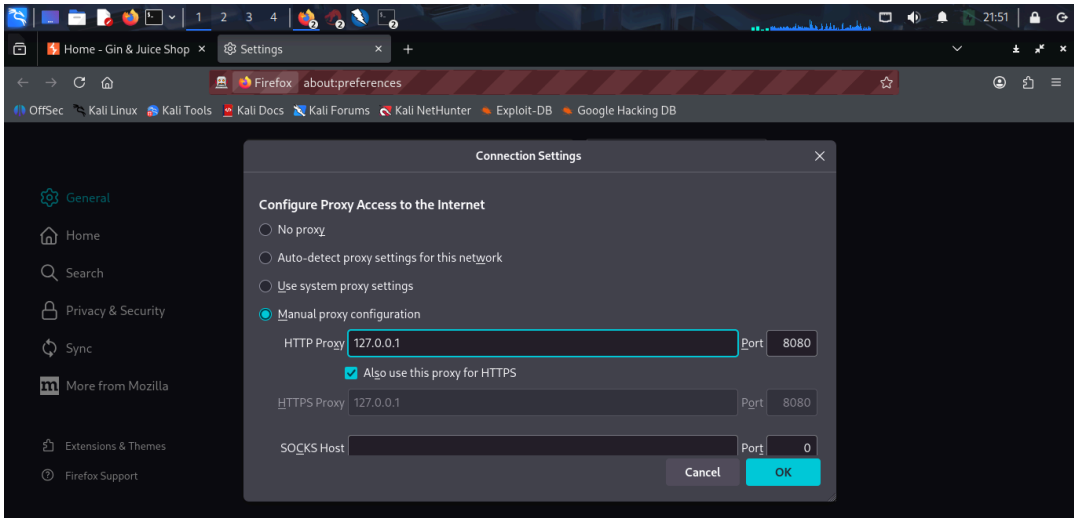
EVALUACIÓN DE SEGURIDAD WEB CON OWASP ZAP

PREPARACIÓN DEL ENTORNO DE TRABAJO

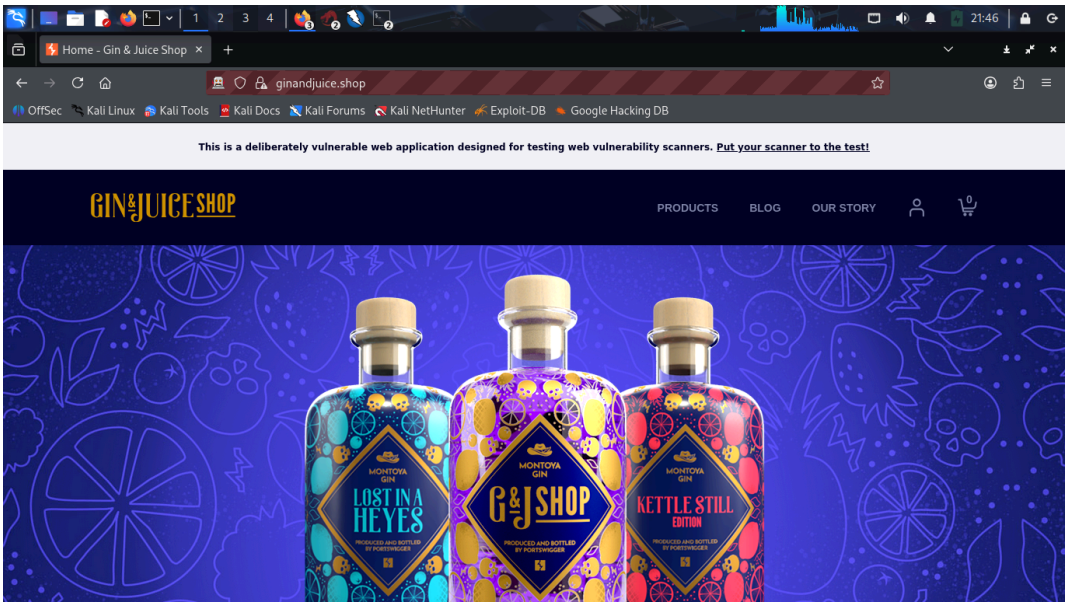
- **Interfaz de OWASP ZAP iniciada en Kali Linux:**



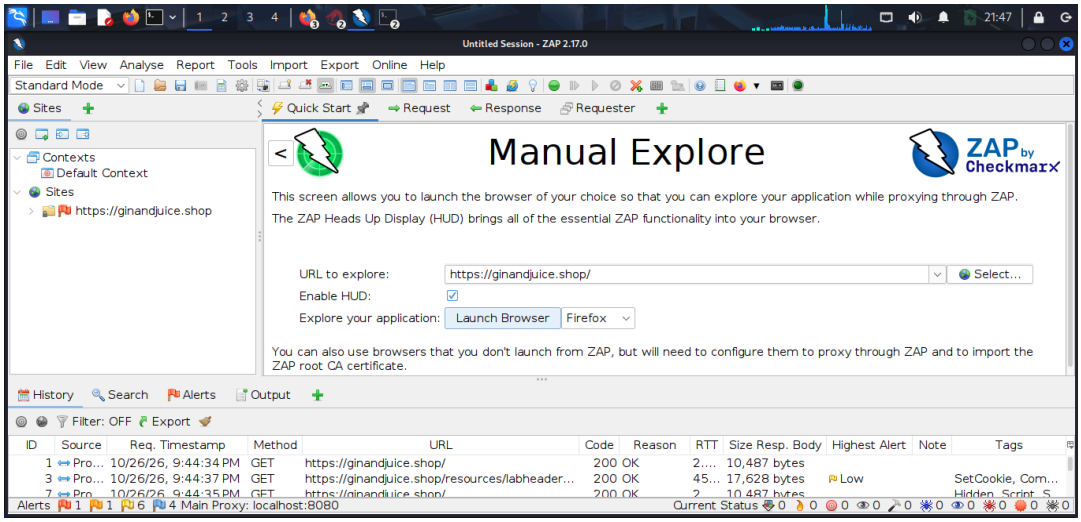
- **Configuración de Proxy HTTP (127.0.0.1:8080) en el navegador:**



- **Acceso exitoso a la aplicación web de prueba Gin & Juice Shop:**

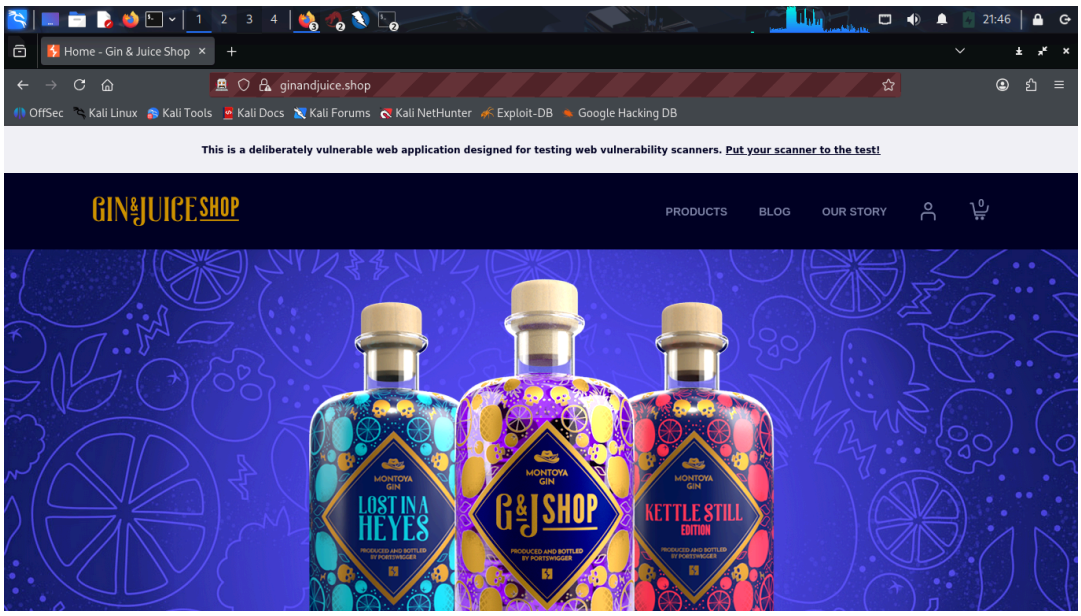


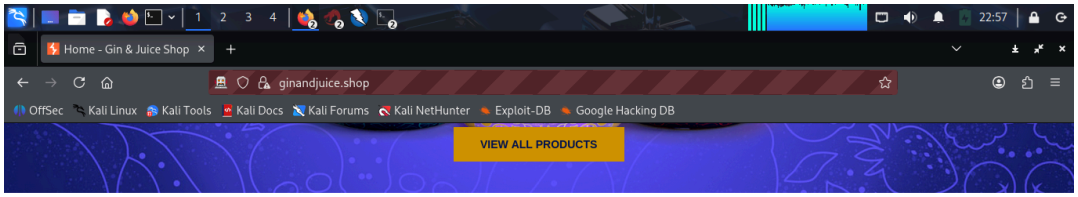
- **Verificación de captura de tráfico en la pestaña History de ZAP:**



EXPLORACIÓN DE LA APLICACIÓN WEB

- **Navegación e interacción con la página principal (Home):**





Created in 2022 by the man Distiller's World has called "the evil genius of gin", Gin & Juice Shop is open 24/7 to satisfy all of your web vulnerability scanner evaluation needs.



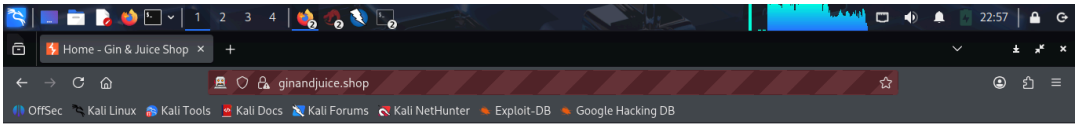
PINEAPPLE EDITION



CREATE YOUR OWN



FRUIT OVERLAYS



NEVER MISS A DEAL - SUBSCRIBE NOW

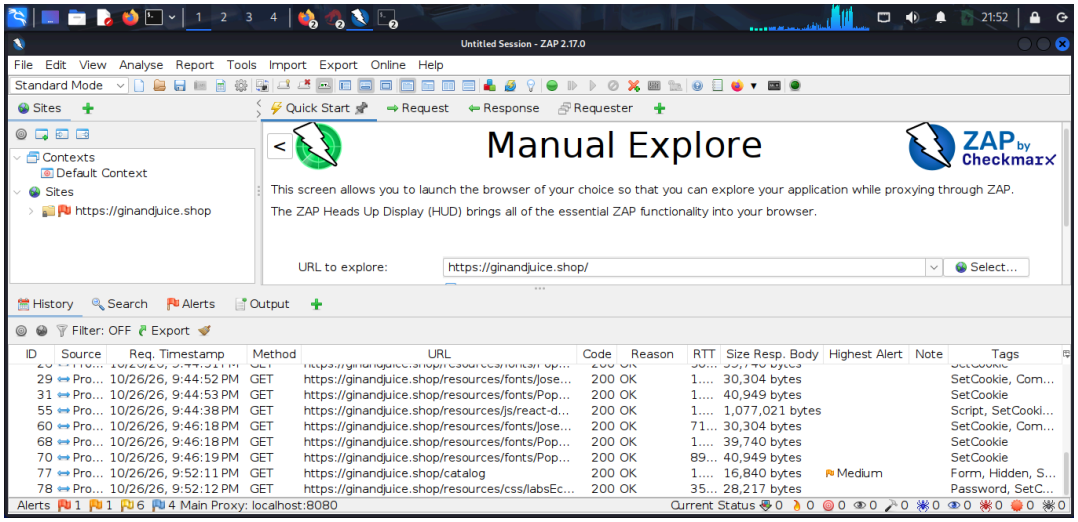
Join our worldwide community of gin and juice fanatics, for exclusive news on our latest deals, new releases, collaborations, and more.

Email address SUBSCRIBE

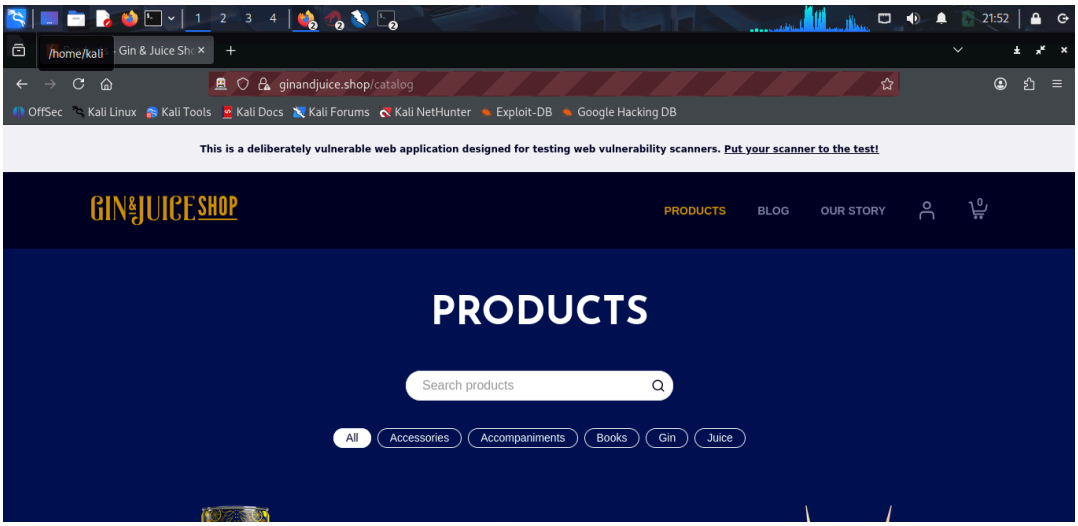
PortSwigger

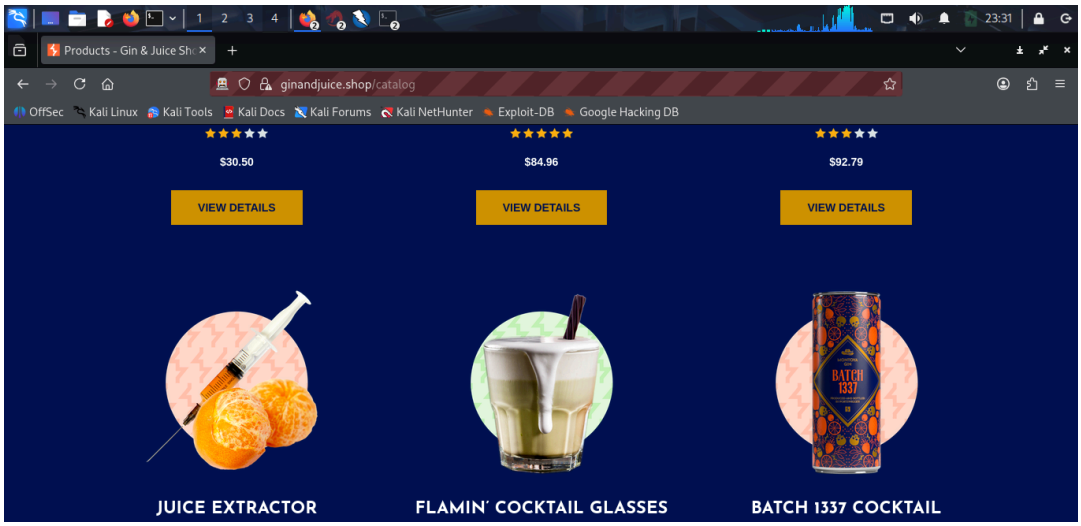
© 2023 PortSwigger Ltd.

PRODUCTS BLOG OUR STORY



- **Navegación por la sección de catálogo de productos:**

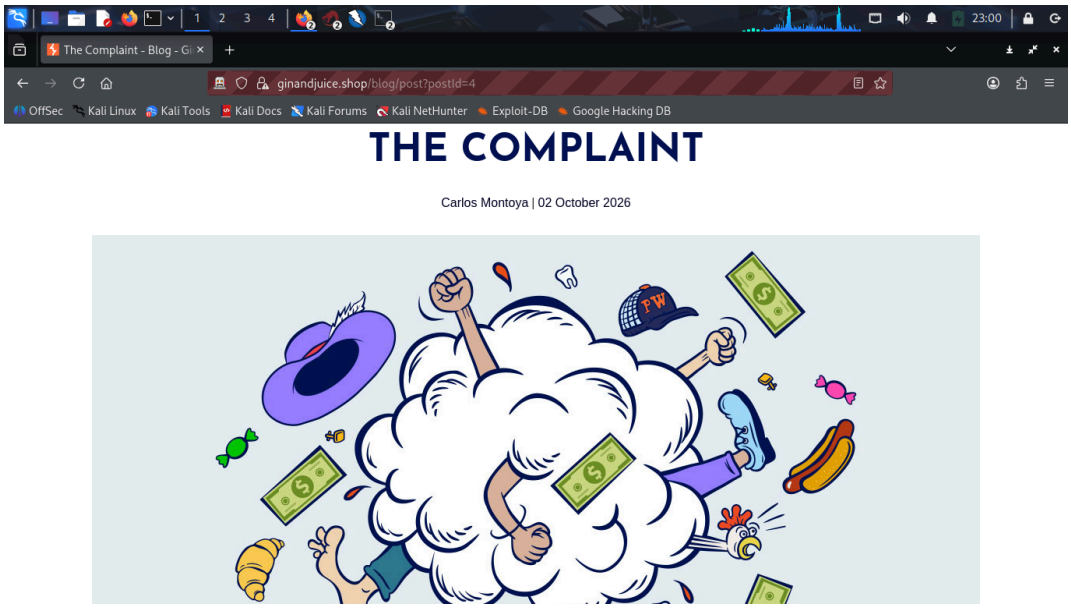




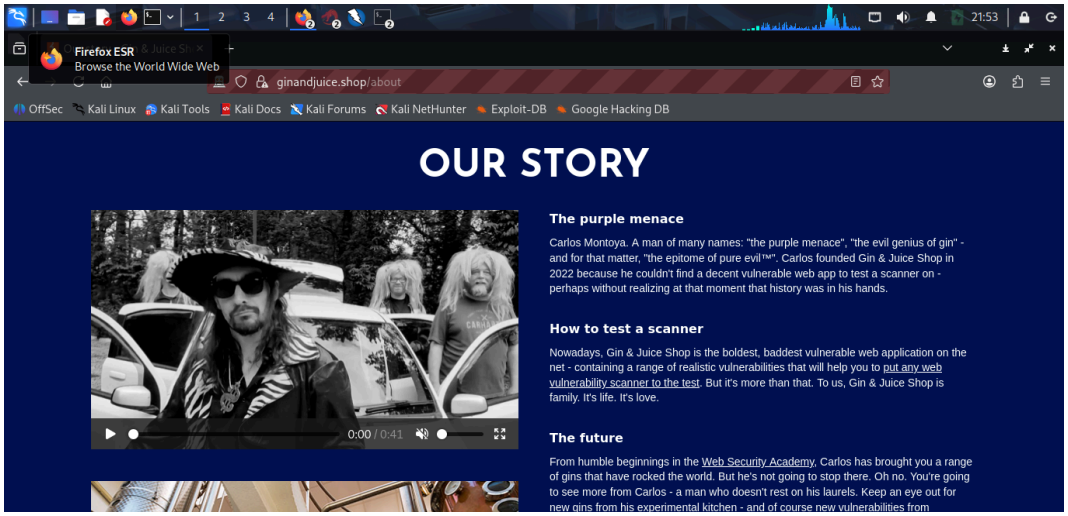
- **Navegación por el Blog del sitio:**



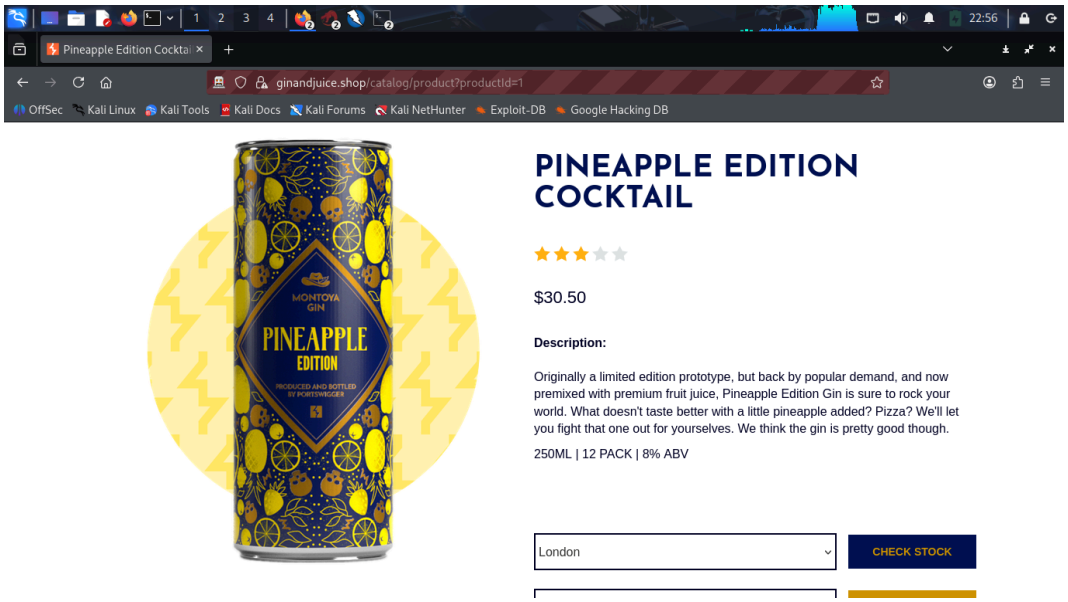
- **Navegación por un artículo del Blog del sitio:**



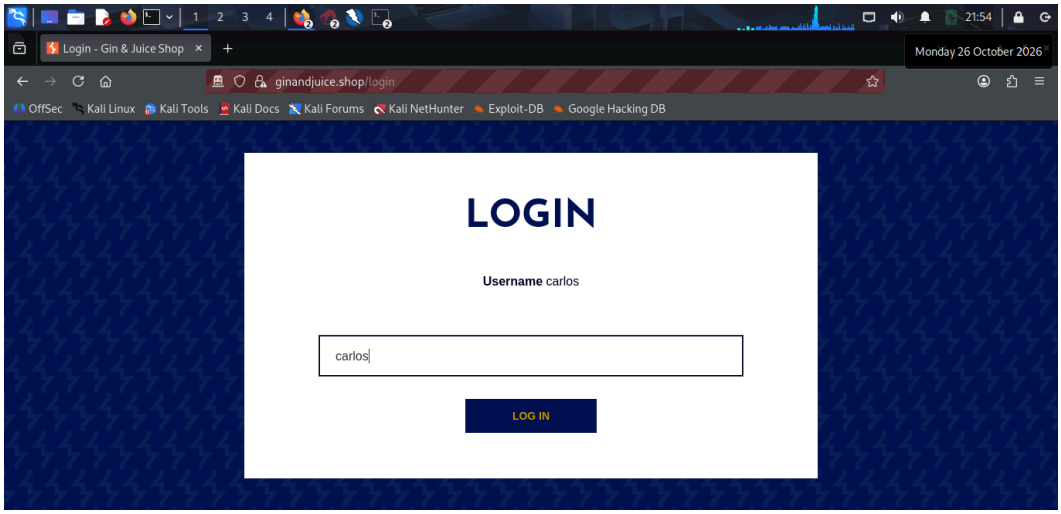
- **Navegación por la sección de nuestra historia del sitio:**

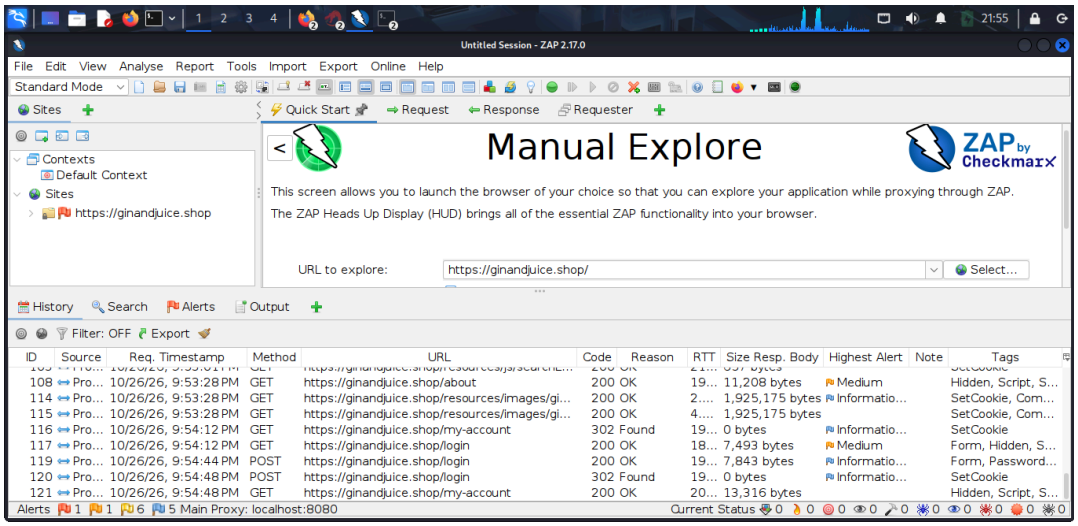


- **Navegación en un producto en específico del sitio:**

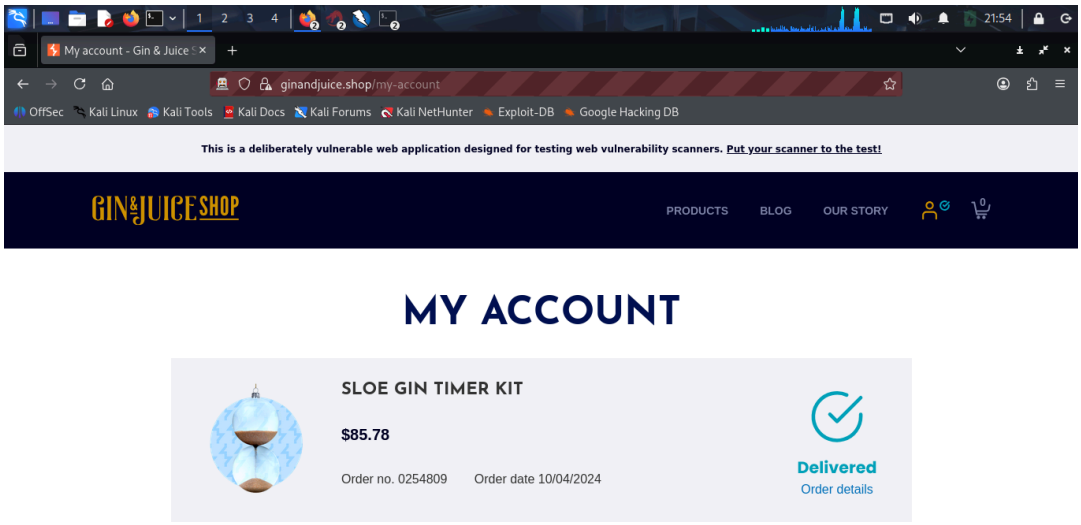


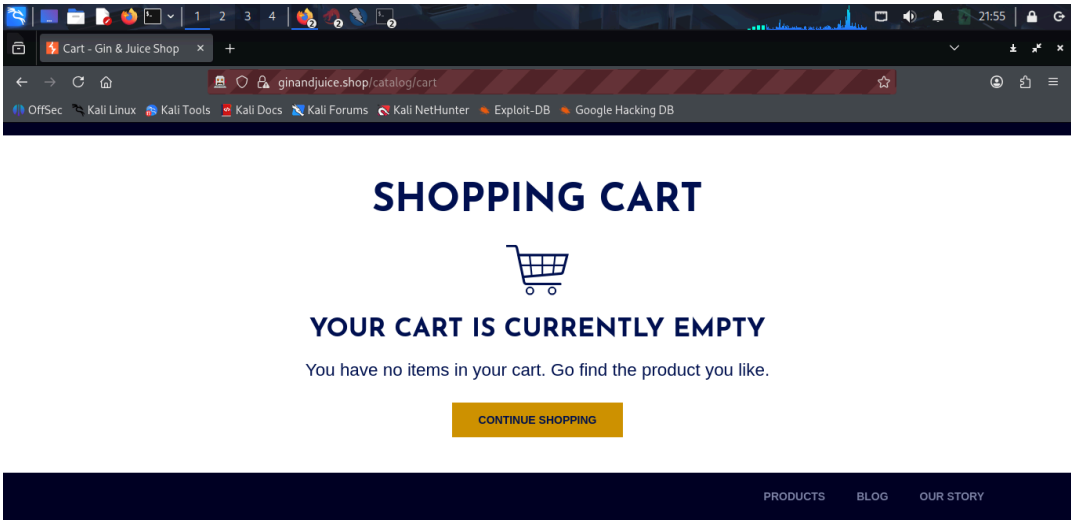
- **Navegación e intento de inicio de sesión en la sección Login:**



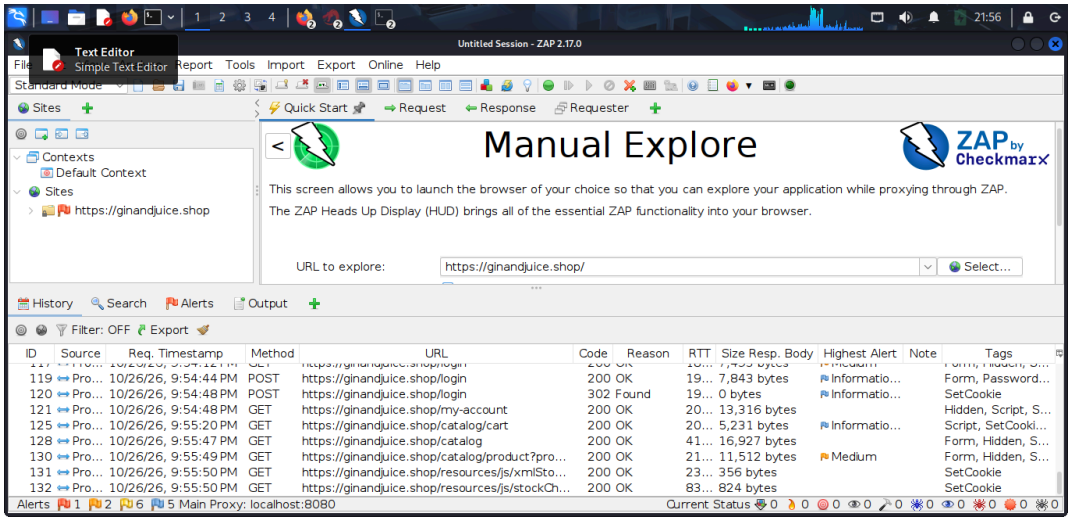


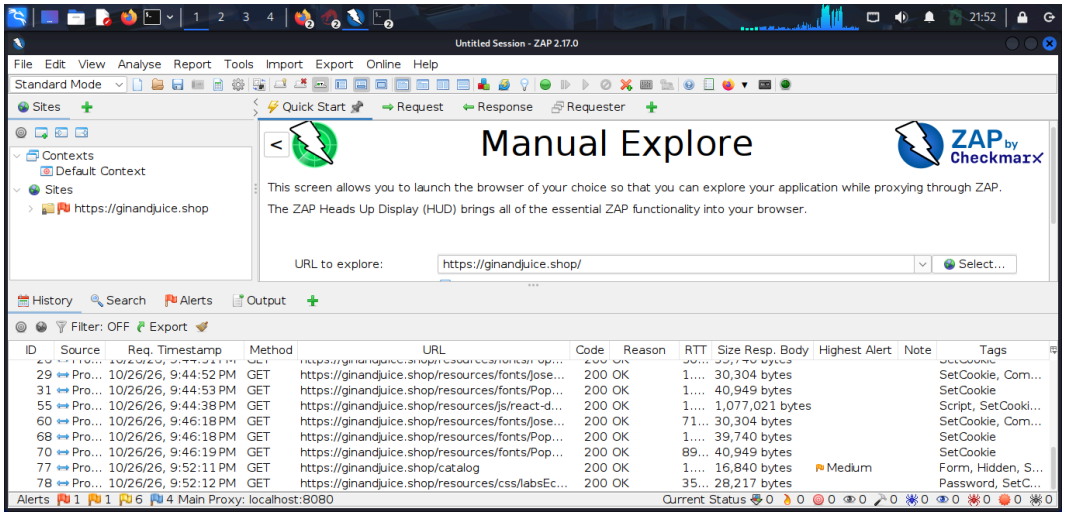
- **Navegación por el perfil de usuario / carrito de compras:**

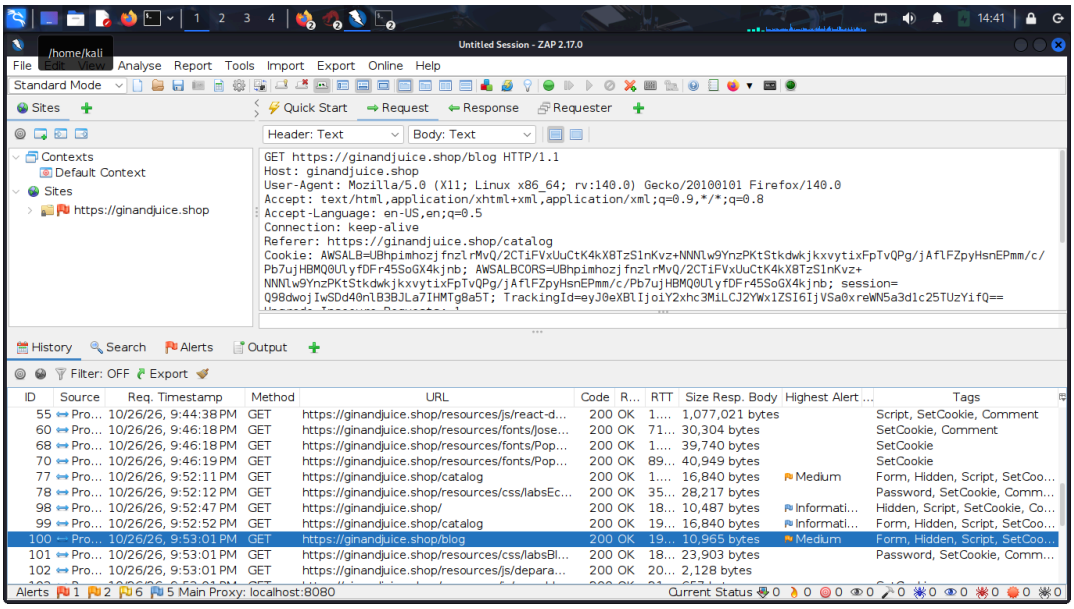




- **Captura general del tráfico HTTP interceptado en ZAP durante la exploración:**



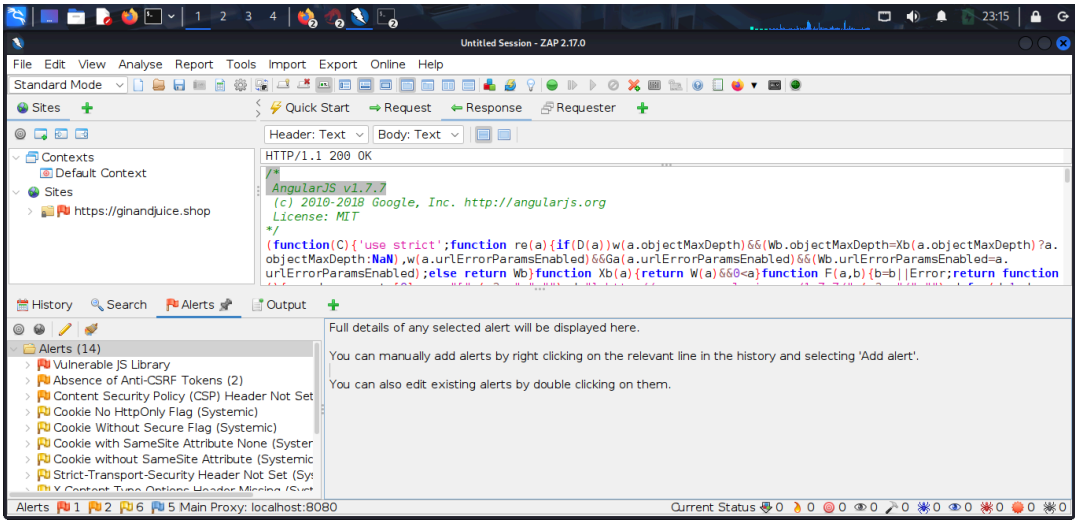




ANÁLISIS GENERAL DE ALERTAS DETECTADAS

Identificación y resumen de las alertas obtenidas durante el análisis pasivo y activo de ZAP que fueron seleccionadas para la documentación detallada:

1. **Vulnerable JS Library** (Riesgo Alto / High)
2. **Absence of Anti-CSRF Tokens** (Riesgo Medio / Medium)
3. **Authentication Request Identified** (Riesgo Informativo / Informational)

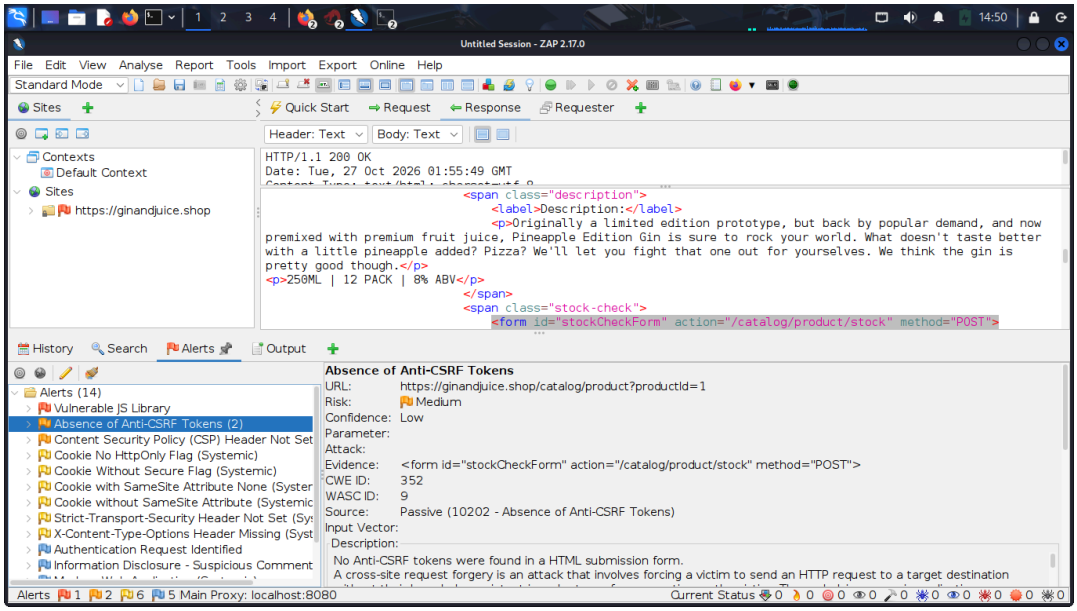


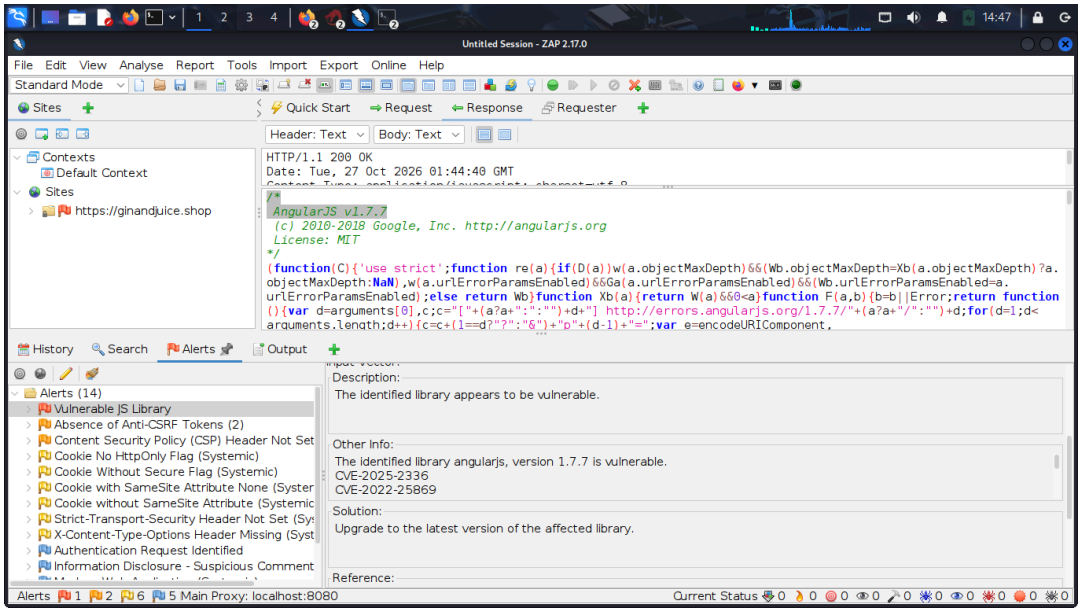
DOCUMENTACIÓN DE HALLAZGO PRINCIPAL

FICHA TÉCNICA 1: VULNERABLE JS LIBRARY (RIESGO ALTO)

Campo	Detalle del Hallazgo
Nombre de la alerta	Vulnerable JS Library
Nivel de riesgo	High (Confianza: Medium)
Componente afectado	`Recurso JavaScript cliente de la aplicación (angular_1-7-7.js)`
Parámetro afectado	Ninguno (Librería JavaScript ejecutada en cliente)
Evidencia identificada	`AngularJS v1.7.7`
Descripción técnica	ZAP identificó el uso de la librería cliente AngularJS versión 1.7.7 mediante el módulo Retire.js. Esta versión cuenta con

Campo	Detalle del Hallazgo
	vulnerabilidades conocidas (CWE-1395) asociadas a fallos de Cross-Site Scripting (XSS).
Impacto potencial	Permite a un atacante aprovechar vulnerabilidades públicas para ejecutar script malicioso en la sesión del usuario.
Recomendación	Actualizar la librería a una versión con soporte de seguridad activo o migrar a un framework moderno.

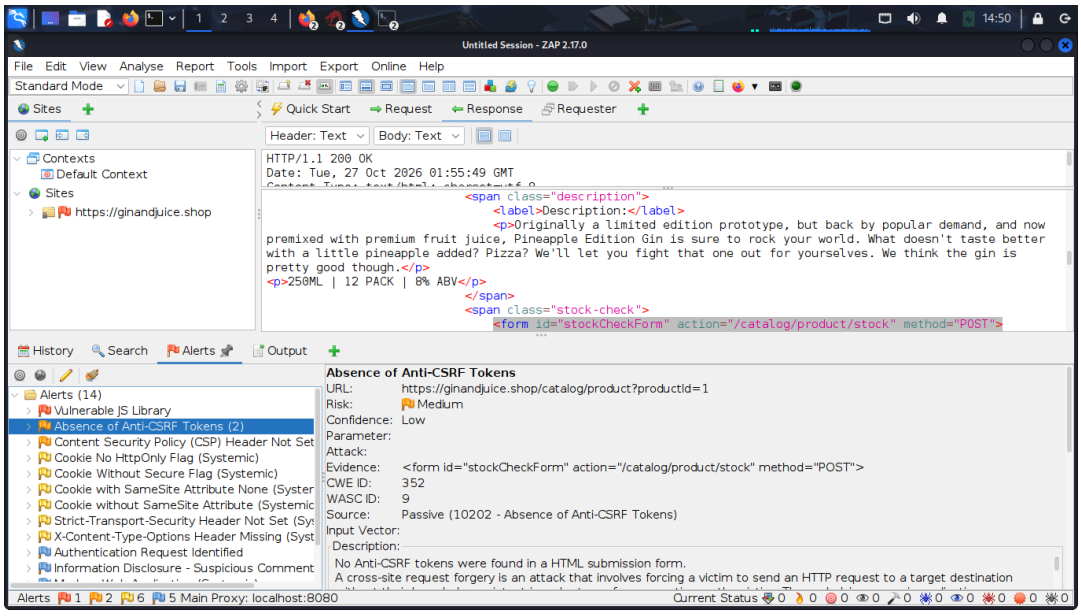


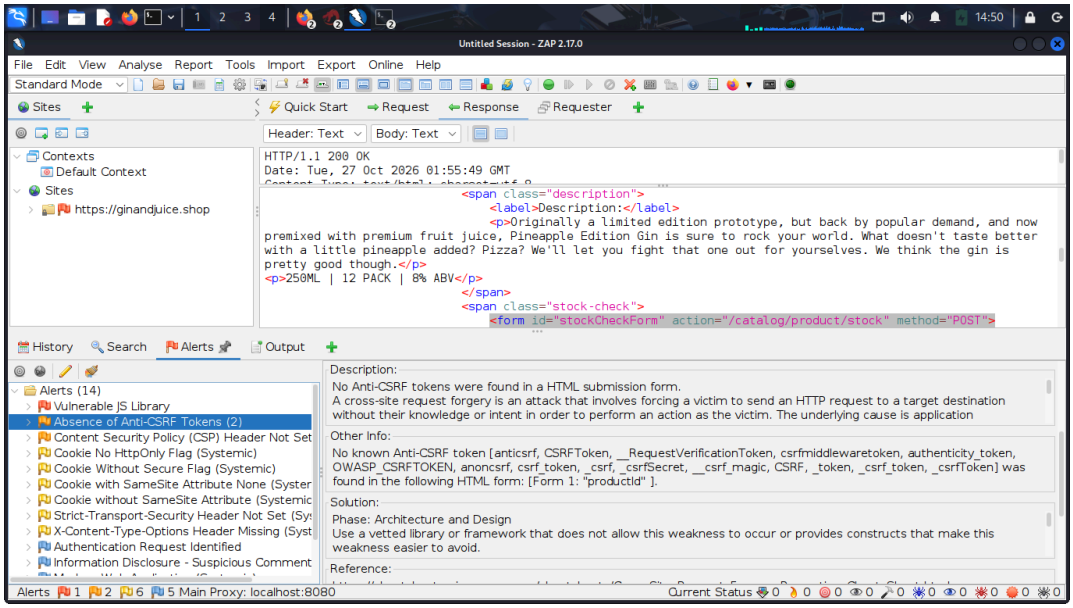


FICHA TÉCNICA 2: ABSENCE OF ANTI-CSRF TOKENS (RIESGO MEDIO)

Campo	Detalle del Hallazgo
Nombre de la alerta	Absence of Anti-CSRF Tokens
Nivel de riesgo	Medium (Confianza: Low)
Componente afectado	`Endpoint del catálogo de productos`
Parámetro afectado	No aplica directamente en URL (Formulario enviado por método POST)
Evidencia identificada	`<form id="stockCheckForm" action="/catalog/product/stock" method="POST">`

Campo	Detalle del Hallazgo
Descripción técnica	El formulario de comprobación de stock envía peticiones por POST sin token único de protección anti-CSRF.
Impacto potencial	Permite realizar solicitudes no autorizadas en nombre de un usuario autenticado aprovechando su sesión activa.
Recomendación	Implementar tokens aleatorios por sesión (Anti-CSRF Tokens) en formularios POST/PUT.

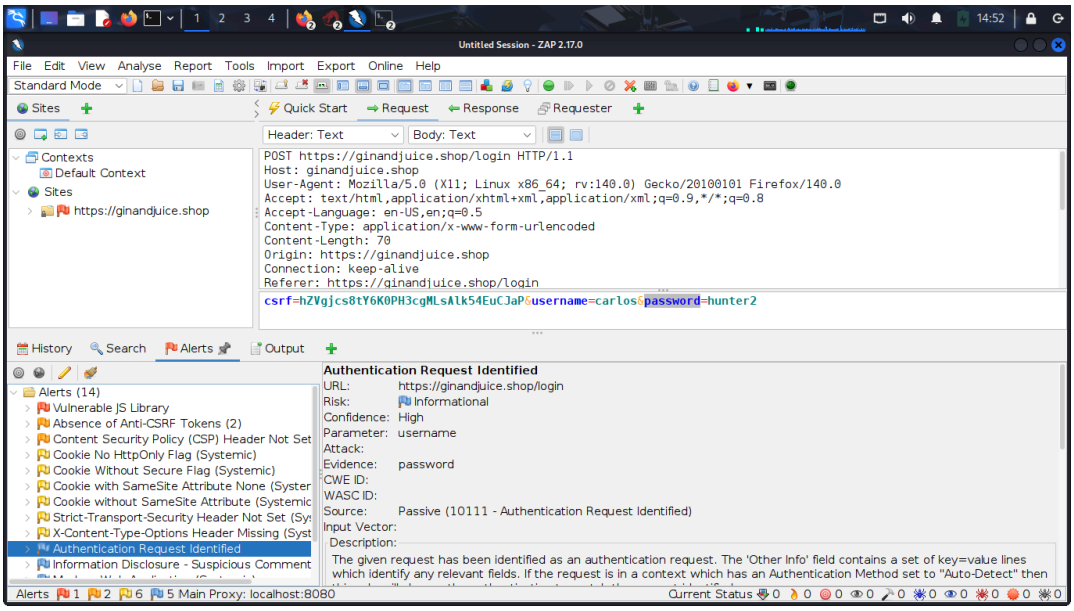


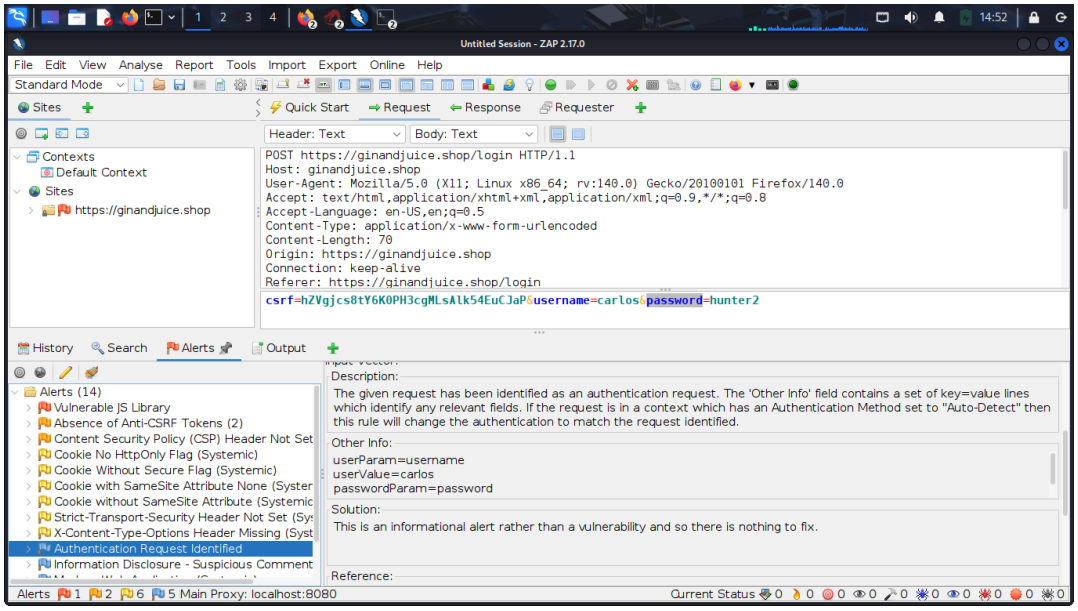


FICHA TÉCNICA 3: AUTHENTICATION REQUEST IDENTIFIED (RIESGO INFORMATIVO)

Campo	Detalle del Hallazgo
Nombre de la alerta	Authentication Request Identified
Nivel de riesgo	Informational (Confianza: High)
Componente afectado	`Endpoint de inicio de sesión (/login)`
Parámetro afectado	`username`
Evidencia identificada	`password`
Descripción técnica	ZAP identificó solicitudes de autenticación que transmiten credenciales de usuario en el cuerpo de la petición.

Campo	Detalle del Hallazgo
Impacto potencial	Permite identificar vectores de entrada de credenciales para comprobar cifrado de transporte y resistencia a fuerza bruta.
Recomendación	Forzar HTTPS de forma estricta y aplicar mecanismos de rate-limiting.





CONCLUSIONES DEL REPORTE

Dificultades encontradas y cómo se resolvieron

Lo más desafiante de esta actividad fue comprender la correlación entre el tráfico web interceptado en tiempo real y la interpretación de las alertas de seguridad generadas por la herramienta. Configurar correctamente el proxy para enrutar el tráfico de la tienda Gin & Juice Shop requirió atención en los detalles de red; sin embargo, esto se resolvió utilizando el navegador preconfigurado de OWASP ZAP, lo que permitió un flujo de trabajo fluido y sin interrupciones en la captura de evidencias.

Aprendizaje obtenido con OWASP ZAP

A través de esta práctica comprendí el funcionamiento de un escáner de vulnerabilidades web automatizado. OWASP ZAP me proporcionó información sumamente valiosa sobre la postura de seguridad de una aplicación, permitiéndome identificar tanto vulnerabilidades activas como fallas de configuración pasivas (tales como la ausencia de cabeceras de

seguridad y tokens de protección), lo cual refuerza la importancia de aplicar buenas prácticas de desarrollo seguro desde las primeras etapas.

Pruebas adicionales a realizar en un entorno real

En un escenario o auditoría de seguridad real, el siguiente paso consistiría en realizar un análisis activo y pruebas de penetración manuales (como explotación controlada de inyecciones SQL y pruebas de lógica de negocio en los formularios de autenticación). Asimismo, verificaría a profundidad la sanitización de entradas de usuario y evaluaría la robustez de los controles de sesión en todas las rutas críticas del sistema.

TABLA RESUMEN DE HALLAZGOS (REPORTE FINAL)

Risk Level	Name	URL	Parameter	Evidence
High	Vulnerable JS Library	`/resources/js/angular_1-7-7.js`	-	`AngularJS v1.7.7`
Medium	Absence of Anti-CSRF Tokens	`/catalog/product?productId=1`	-	`<form id="stockCheckForm" action="/catalog/product/stock" method="POST">`
Informational	Authentication Request Identified	`/login`	`username`	`password`